Cryptographic Deniability

A Multi-perspective Study of User Perceptions and Expectations

Tarun Kumar Yadav, **Devashish Gosain**, Kent Seamons

USENIX Security Symposium 2023 ·

Today’s roadmap

1 **Background**
Authentication properties, MACs vs signatures, OTR & Signal

2 **Framing the problem**
Three acceptances, six harms, research questions

3 **Interviews**
What 12 users think a chat proves

4 **Survey**
664 participants: trust, understanding, preferences

5 **Legal analysis**
228 US court cases involving WhatsApp chats

6 **Discussion**
Takeaways, limitations, activity, open problems

Learning objectives



Define non-repudiation, deniability and anonymity, and tell them apart with examples



Explain why MAC-based authentication gives deniability and signatures do not (OTR, Signal)



Argue why a cryptographic property needs social and legal acceptance to protect anyone



Interpret a mixed-methods usable-security study: interviews, survey, legal case analysis



Critique design choices: should deniability be the default in messaging apps?

Warm-up: would you believe it?

Scenario

A classmate you don’t fully trust tells you that your close friend has been mocking you behind your back.

- A. They just tell you
- B. They show you a screenshot of the chat
- C. They open WhatsApp and show you the chat on their phone



Rate your trust in each case from 1 (none) to 10 (complete)

Then ask yourself:

- Could your classmate have forged C?
- Does WhatsApp’s cryptography let them?
- Would a court accept C as evidence?

Part 1

Background

What does a chat prove? Authentication properties and how protocols achieve deniability

Three authentication properties



Non-repudiation

“Indisputable”

Sender’s identity is cryptographically bound to the message. The recipient can prove to anyone who sent it.

e.g. PGP, S/MIME, DKIM-signed email



Deniability

“Disputable”

Recipient can verify the sender, but cannot prove it to a third party. Anyone could have produced the transcript.

e.g. OTR, Signal, WhatsApp



Anonymity

Sender’s identity is not bound to the message at all. Even the recipient doesn’t know who sent it.

e.g. Tor, anonymous remailers

Who can convince whom?

Alice (sender) → Bob (recipient) : Nash (third party)

Non-repudiation	Bob shows Nash the message	→	*Nash: "Indeed, Alice sent you this."* 
Deniability	Bob shows Nash the message	→	*Nash: "I can't verify that — you could have forged it."* 
Anonymity	Bob receives the message	→	*Bob: "I'm not sure who sent this."* 

Adapted from Figure 4 of the paper (the diagram shown to survey participants).

Where deniability comes from

Digital signature

- Only Alice holds the signing key sk
- Anyone with Alice's public key pk can verify
- Bob could not have produced σ himself
- ⇒ σ is transferable proof: non-repudiation

Message authentication code (MAC)

- Alice and Bob share a key k (e.g. from Diffie–Hellman)
- Bob verifies tag = MAC(k, m): it wasn't him, so it was Alice
- But Bob could have computed the same tag and modified the message
- ⇒ convincing to Bob, worthless to Nash: deniability

Key idea: authentication that relies only on secrets both parties hold can never prove to an outsider which of the two parties acted.

Off-the-Record (OTR) messaging, 2004

1

Deniable AKE

Signed Diffie–Hellman exchange authenticates the session key, not the messages

2

MAC every message

Messages are authenticated with MAC keys derived from the shared secret

3

Publish old MAC keys

After use, MAC keys are revealed so anyone could forge past transcripts

4

Malleable encryption

Counter-mode lets a forger alter ciphertexts to say anything

OTR's user-facing definition (used verbatim in the study): *messages carry no signatures a third party can check; anyone can forge messages after a conversation; yet during the conversation your correspondent is assured messages are authentic.*

Borisov, Goldberg, Brewer, "Off-the-record communication, or, why not to use PGP", WPES 2004.

From OTR to billions of users



OTR

2004 · Pidgin/Adium plug-in

research prototype

Signal

X3DH + Double Ratchet

more than 40 million active users

WhatsApp

Signal protocol, on by default

more than 2 billion active users

Signal's X3DH authenticates with Diffie–Hellman shares rather than signatures over messages, so transcripts are deniable (formal analysis: Vatandas et al., ACNS 2020). Users never chose this — it is the default.

Experts disagree: deniability by default?

Analysis of an 81-message moderncrypto.org thread (19 experts, Dec 2014)

For deniability	Against / reservations
• E1 Mimics private face-to-face conversation • E2 Matches the past: unencrypted apps were deniable • E3 Protects senders such as journalists and whistleblowers	• E4 People need proof: business deals happen over chat • E5 Ordinary users can't forge messages, so claims of forgery aren't credible • E6 Without awareness there is no social or legal acceptance

These six claims became hypotheses the user study could test.

Discussion break 1



Pairs

1. Which side of the expert debate do you find more convincing, and why?

2. Name one situation in your own life where you wanted non-repudiation, and one where you wanted deniability.

3. If deniability works only when people know about it, should apps advertise it? How?

Part 2

Framing the problem

Why a proven property can still fail users

Why does deniability need to be studied?

In theory, we've solved deniability. In practice, it also requires…



Awareness by the sender

A sender who doesn't know a message is deniable can't deny it



Acceptance by others

Friends, employers and the public must accept that a chat could be forged

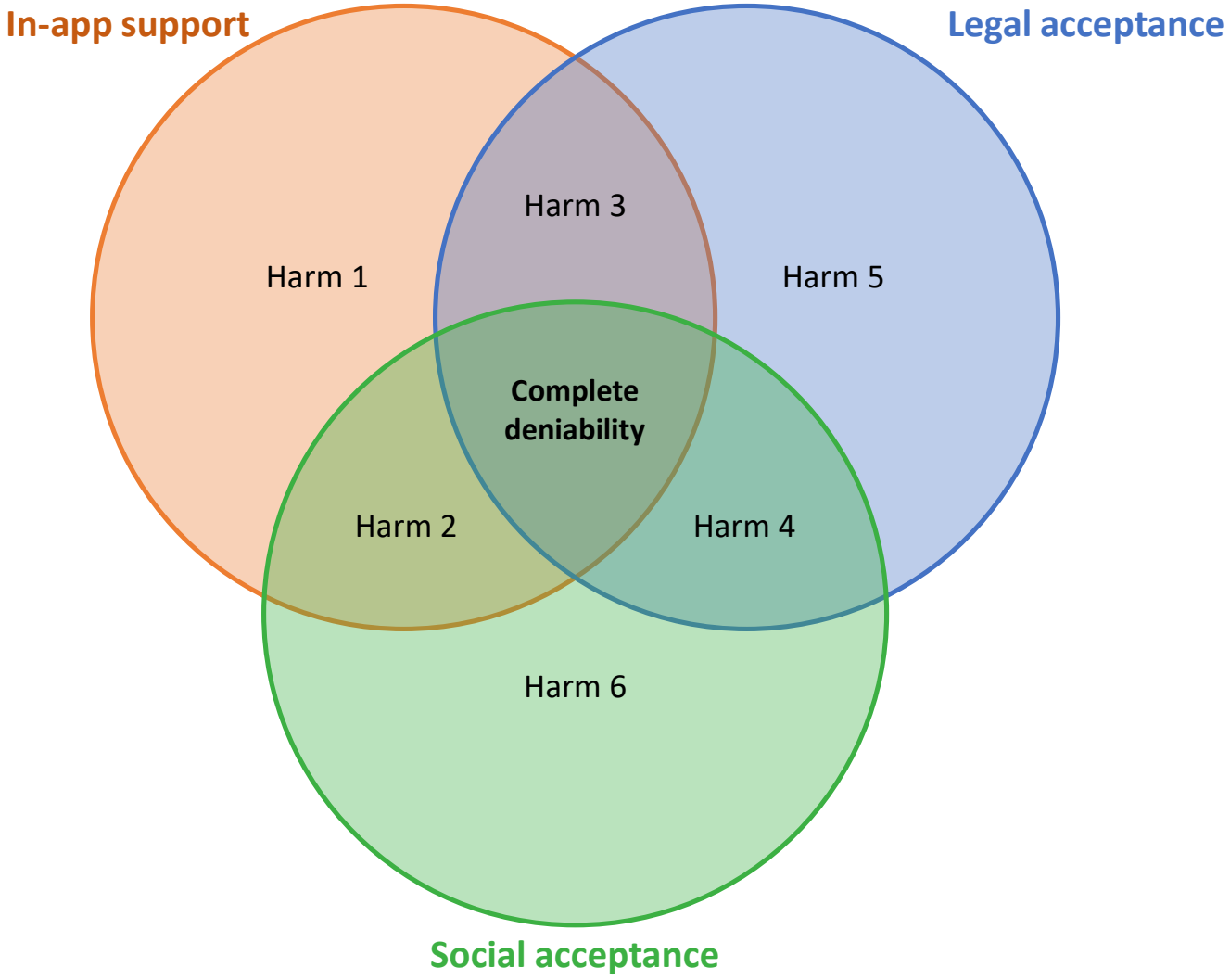


Acceptance by the legal system

Courts must treat a chat as forgeable evidence

If these are missing, users can experience tangible harms.

Potential harms



Harm 1

App offers deniability (messages cannot be used as evidence)

Society is not aware of deniability (thinks messages can be used as evidence)

The legal system is not aware of deniability (thinks messages can be used as evidence)

Consequence: an attacker can forge a chat that friends and courts will believe.

Six ways the pieces can fail to line up

	In-app	Social	Legal	What goes wrong
Harm 1	✓	✗	✗	Forged messages trusted socially and legally
Harm 2	✓	✓	✗	Users think they can deny in court, but cannot
Harm 3	✓	✗	✓	Users think chats are evidence; courts disagree
Harm 4	✗	✓	✓	Users deny messages that are in fact provable
Harm 5	✗	✗	✓	Courts discount genuine, provable evidence
Harm 6	✗	✓	✗	Users assume they can deny; courts accept the chat

Harms 1–3: the app supports deniability. Harms 4–6: it doesn't, but people act as if it did.

Research questions

RQ1	**Social acceptance**	How acceptable is it for a sender to deny a real WhatsApp chat to a third party? How does that compare with denying something said orally?
RQ2	**Understanding**	What do users understand by deniability after reading OTR's standard definition?
RQ3	**Preferences**	Which properties — deniability, non-repudiation, anonymity — do users want, for which applications, and why?
RQ4	**Legal acceptance**	How credible is a WhatsApp chat as evidence in US courts?

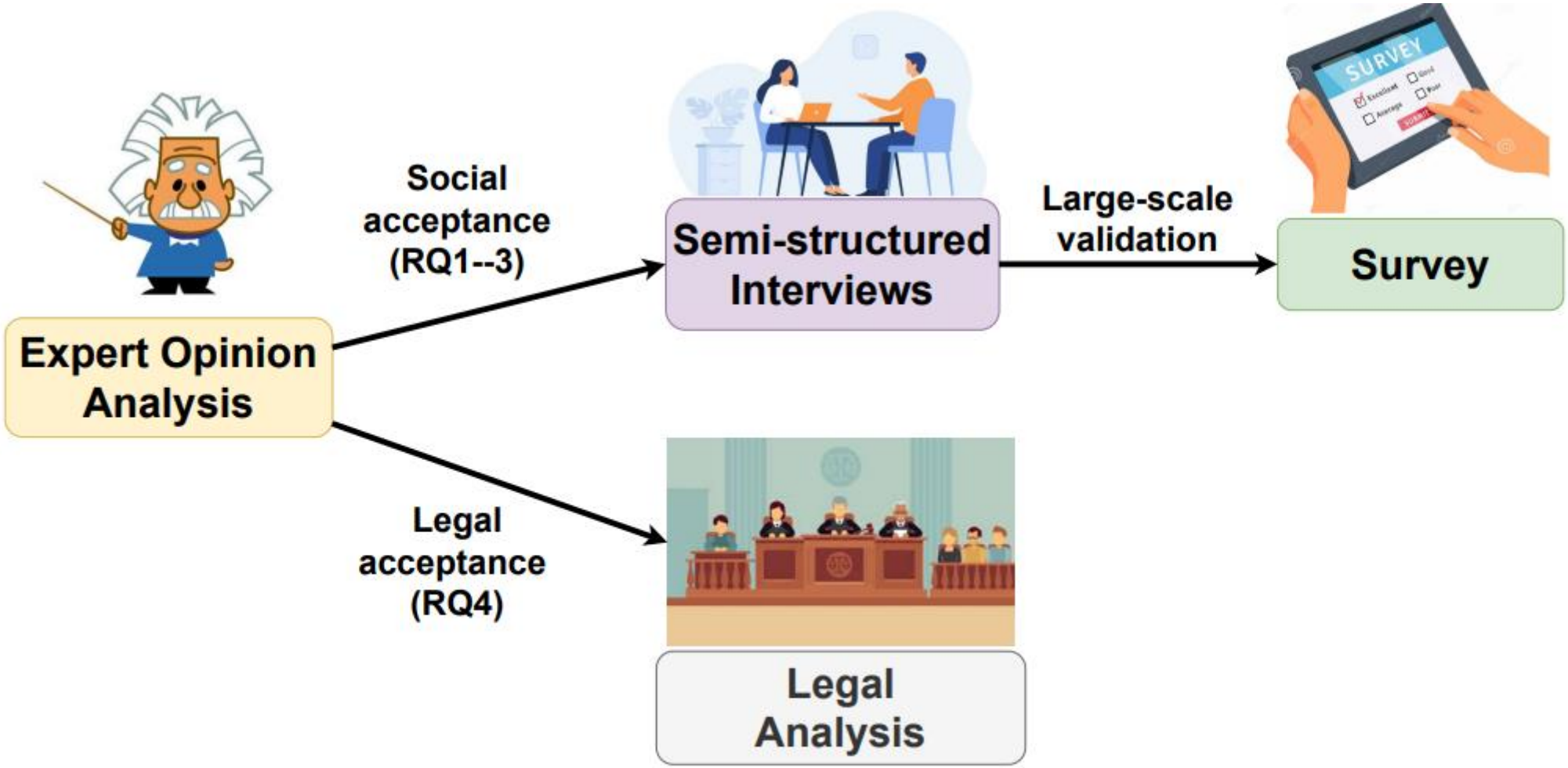
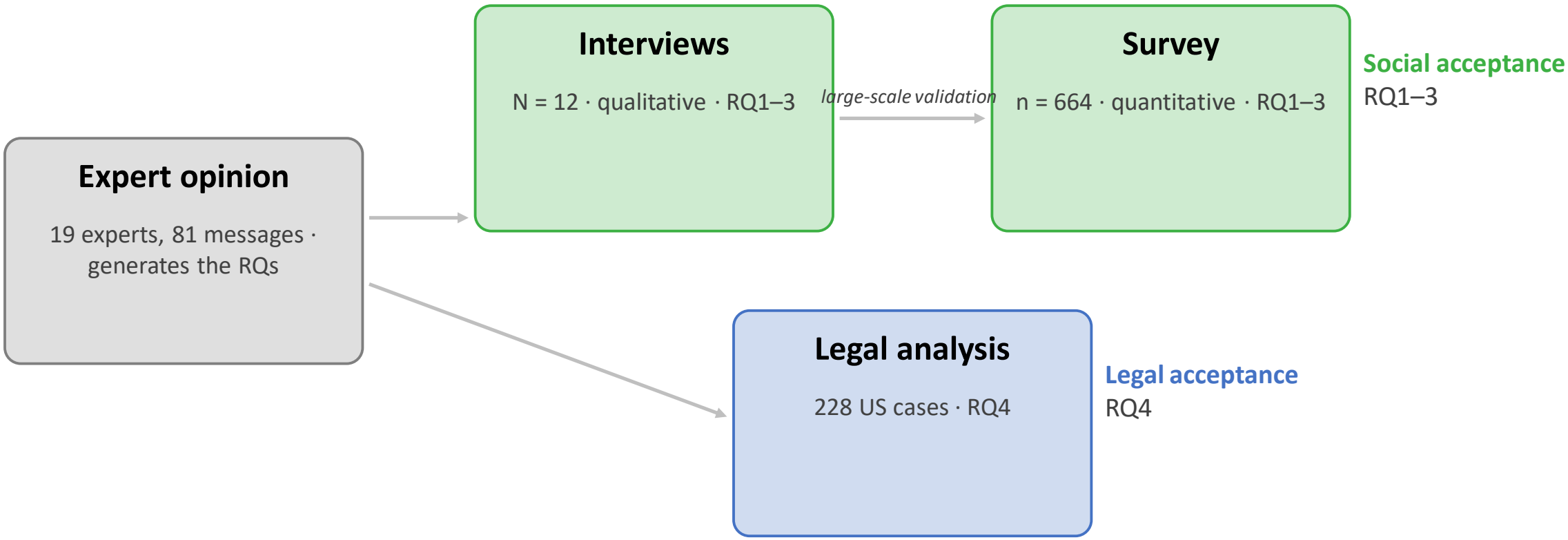


Figure 2: Overview of our approach.

A multi-method design



Why mixed methods? Interviews find themes and wording; the survey measures how common they are; the legal analysis checks real-world outcomes rather than hypotheticals.

Part 3

Semi-structured interviews

N = 12 US participants · 40–60 minutes each

Interview design

12 participants via Prolific (US, used WhatsApp or Signal + email)

40–60 minutes per interview, $13/hour

Until saturation · inductive coding by two researchers, all disagreements reconciled

Gender balance: 5 male, 7 female · ages 21–80

Interview guide

- Draw how a message travels from sender to you (email, WhatsApp, SMS), thinking aloud
- How would you prove to others that someone sent you a message?
- Friend A says friend B badmouthed you — do you believe A? What if A shows you the chat?
- Explain OTR's deniability definition in your own words
- Choose: indisputable, disputable or anonymous — or a combination

As recipients: “I can prove it”



Show a screenshot

favoured by 10 of 12



Forward the message



Show the chat on my phone

preferred if the third party is untrusted

Nobody mentioned that the recipient could have forged it.

And in court?

- 8 of 12: the in-app chat can be presented as evidence
- 2 of 12: a screenshot or screen recording is enough
- Some suggested courts verify it: subpoena WhatsApp, get an ISP transcript, or run forensics

As third parties: the chat changes everything

A tells you orally

No participant trusted A unconditionally; 6 said A should have confronted B directly

A shows you the chat on their phone

9 of 12 fully trusted A — even if A has a history of lying and B is close family

“Even if friend A had a history of making stuff up, or not being the most trustworthy, she’s showing me the texts on her phone what friend B said, then I’d be like, Okay this is legitimate.”

— P6

Mental models and wished-for combinations

Where does a WhatsApp message go?



Through a central server



Through WhatsApp's server



Along a decentralised path



Directly to the recipient

"Direct path" believers expected nobody could read or modify messages — except perhaps the government.

Five ways to combine properties

Person-based: property depends on the contact

Message-based: sender picks per message

App-based: e.g. Gmail deniable, WhatsApp not

Time-based: non-repudiable for an hour, then deniable

Duration-based: property fixed for messages sent in a window

Part 4

Large-scale survey

n = 664 US participants · scenarios, comprehension and preferences

Survey design

931 → started

731 → finished

664 passed the attention check

- Personalised scenarios: participants entered nicknames of a trusted person, an acquaintance and an untrustworthy person
- Attention check: later re-categorise those names; mistakes were discarded (all 731 were still paid)
- Two pilots (n = 13 think-aloud, n = 29 on Prolific) refined wording
- Plain labels “indisputable / disputable” plus diagrams replaced the jargon

Participants

Gender
46% male · 45% female

Age
30% 18–29 · 34% 30–39 · 35% 40+

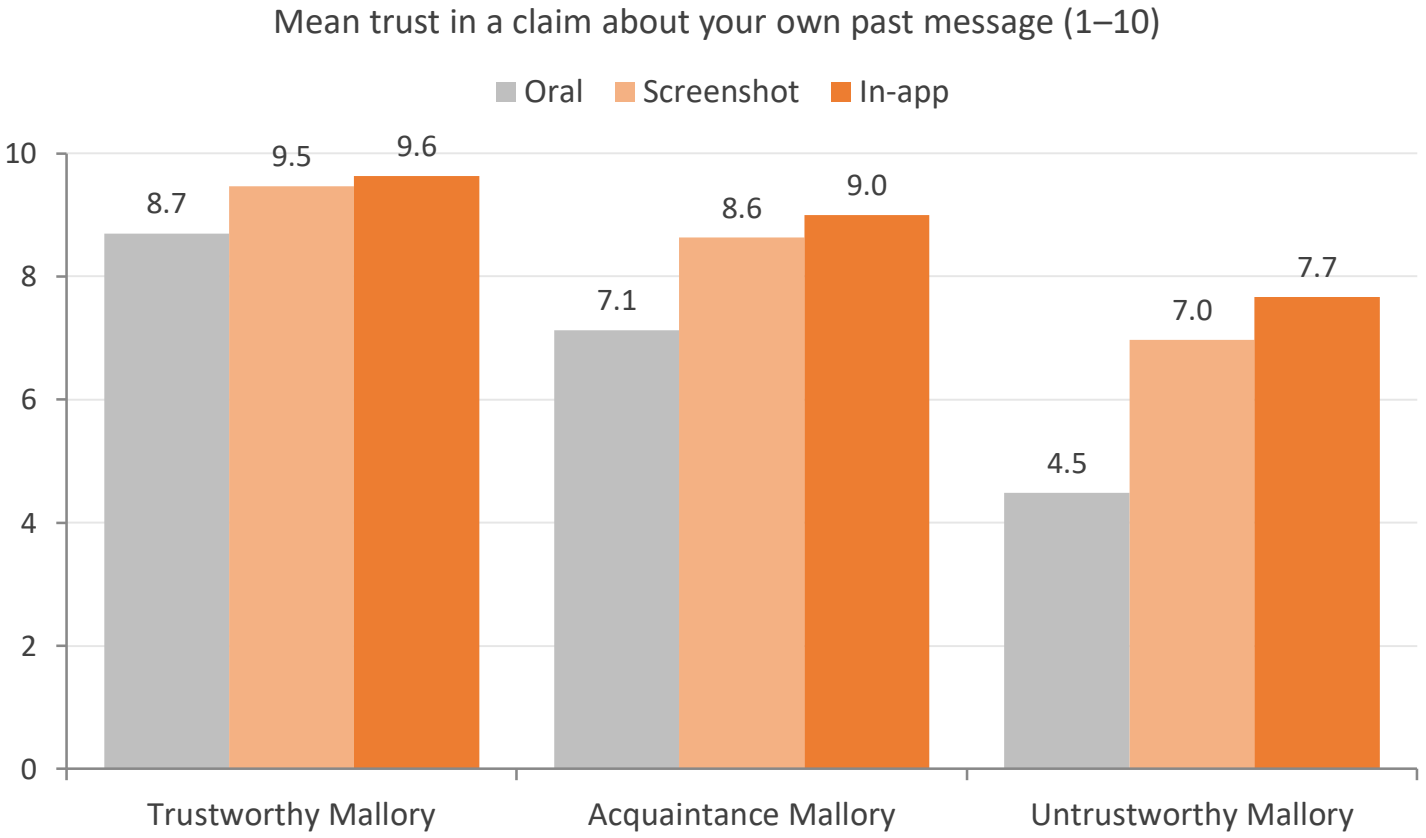
Ethnicity
57% White · 12% Asian · 10% Black

Employment
43% full-time · 11% part-time

Pay
$13.46/hour · median 13 min 40 s

Could a chat convince you of your own past?

“You owe me $50 for dinner last month.” You don’t remember. Mallory says so, shows a screenshot, or shows a chat where you agreed.



+3.19

trust gained by an untrustworthy Mallory who shows an in-app chat

A deniable app makes this chat forgeable — and the victim’s own memory gives way to it.

Data: Table 4. Same ordering as before: in-app > screenshot > oral; trustworthy > acquaintance > untrustworthy (all $p < 0.001$).

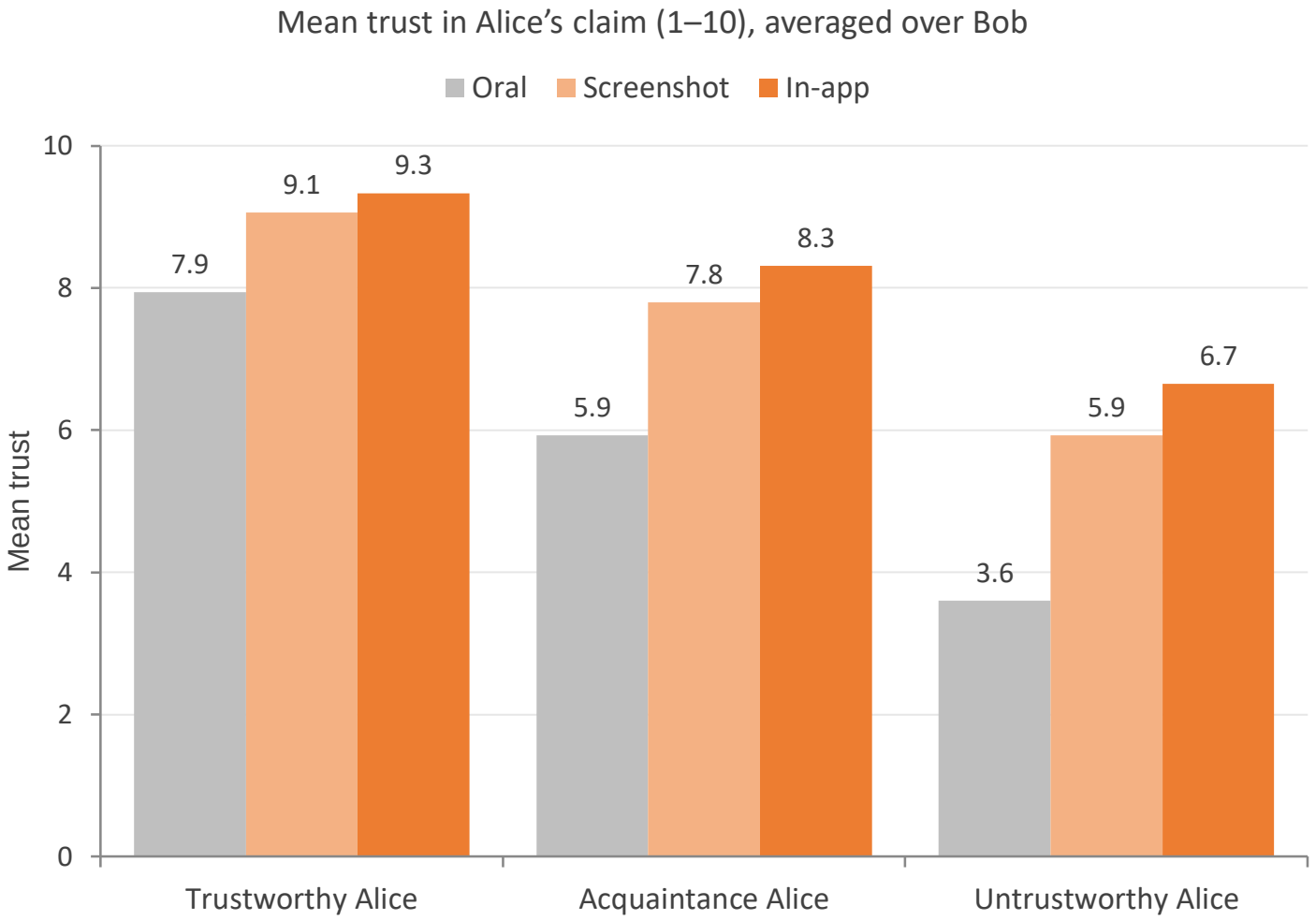
Scenario: Alice says Bob badmouthed you

Participants rated trust in Alice's claim from 1 (none) to 10 (complete) for every combination of three factors — 27 ratings each.

Who is Alice to you? the claimant	×	**Who is Bob to you?** the alleged sender	×	**How does Alice prove it?** the medium
Trustworthy (T)		Trustworthy (T)		Oral (O)
Acquaintance (A)		Acquaintance (A)		Screenshot (S)
Untrustworthy (U)		Untrustworthy (U)		In-app chat (I)

Notation used in the paper: <Alice, Bob, medium>, e.g. <T-T-O> = **trusted Alice orally accuses trusted Bob** (mean trust 7.31).

A chat raises trust



+2.28

in-app vs oral

+0.50

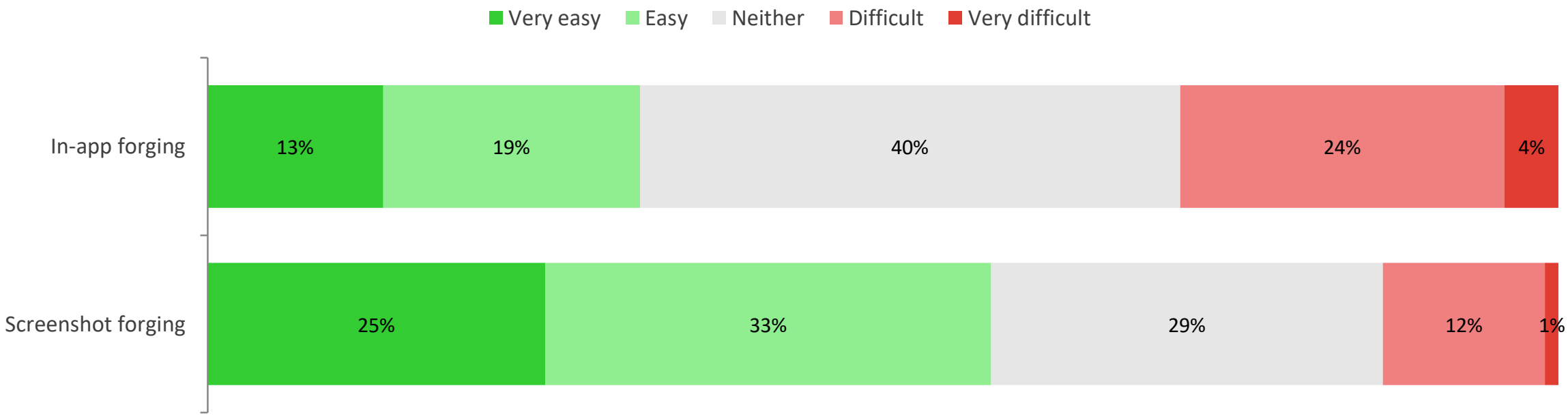
in-app vs screenshot

2.89 → 6.19

untrustworthy Alice accusing trustworthy Bob: oral → in-app

Data: Table 2 and Section 5.2.1. All pairwise differences significant (repeated-measures ANOVA, Bonferroni-corrected, $p < 0.001$).

Easy to fake, trusted anyway



~58%

say a screenshot is easy to forge

~32%

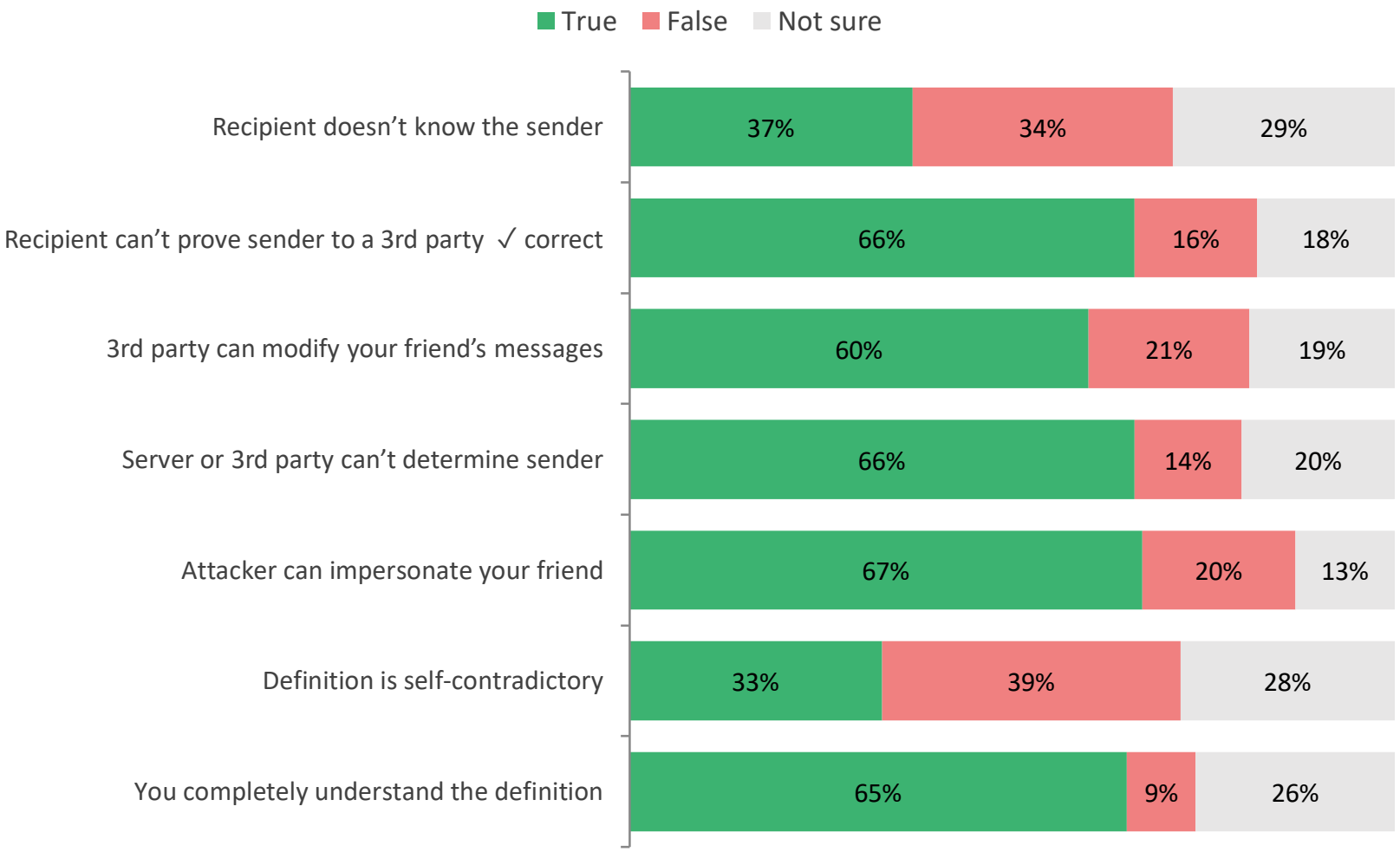
say an in-app chat is easy to forge

r = 0.11

weak link between forging beliefs and the trust jump

Bar values read off Figure 7 (approximate). Pearson r(664) = 0.114, p = 0.003.

Do users understand OTR's definition?



0.6%

marked only the correct statement as true

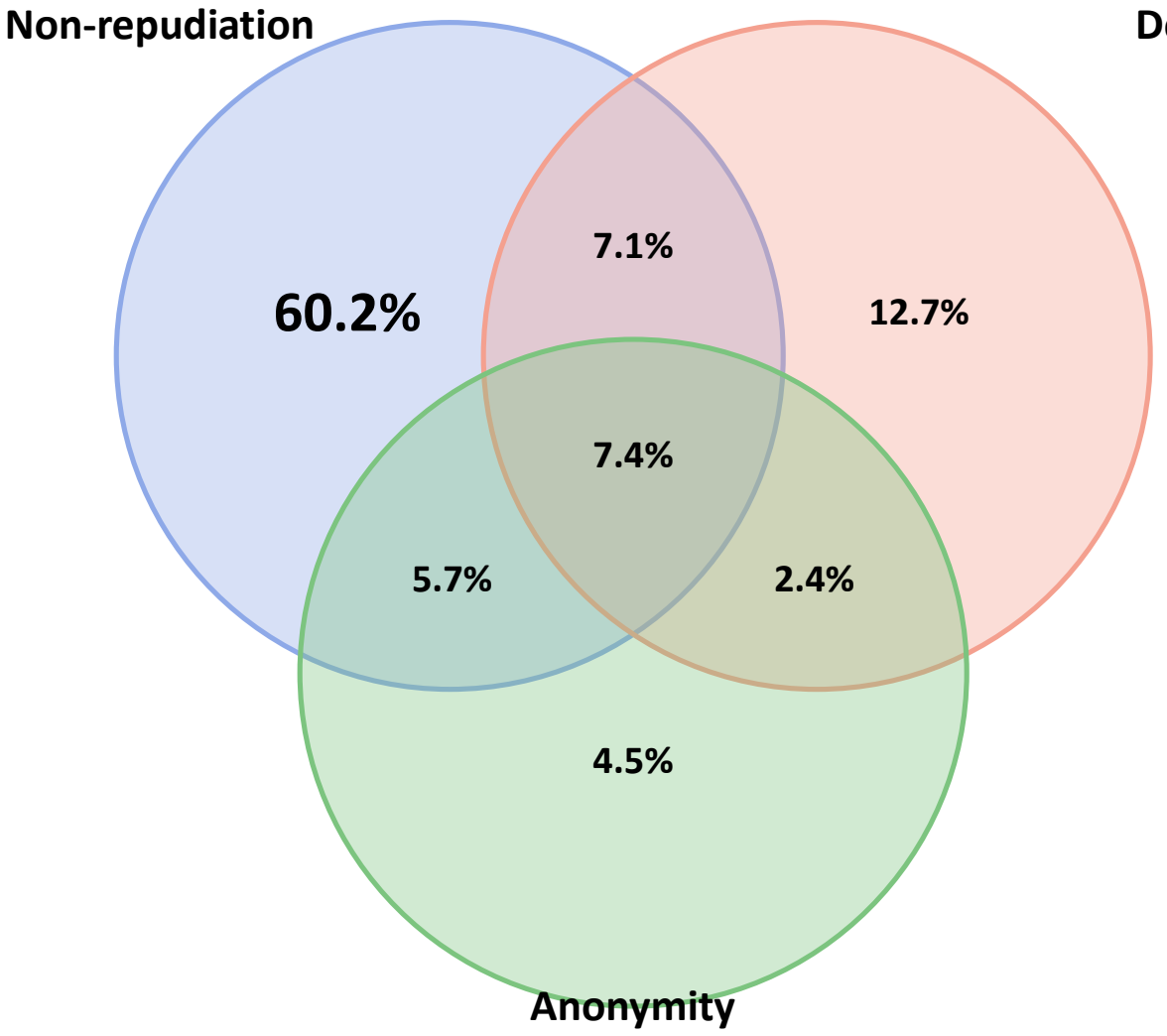
~65%

believed they completely understood it

"Well, none of it makes sense"
— P3

Bar values read off Figure 8 (approximate). Paper reports 64.8% believed they understood but did not; 32% found it self-contradictory.

What do users prefer?

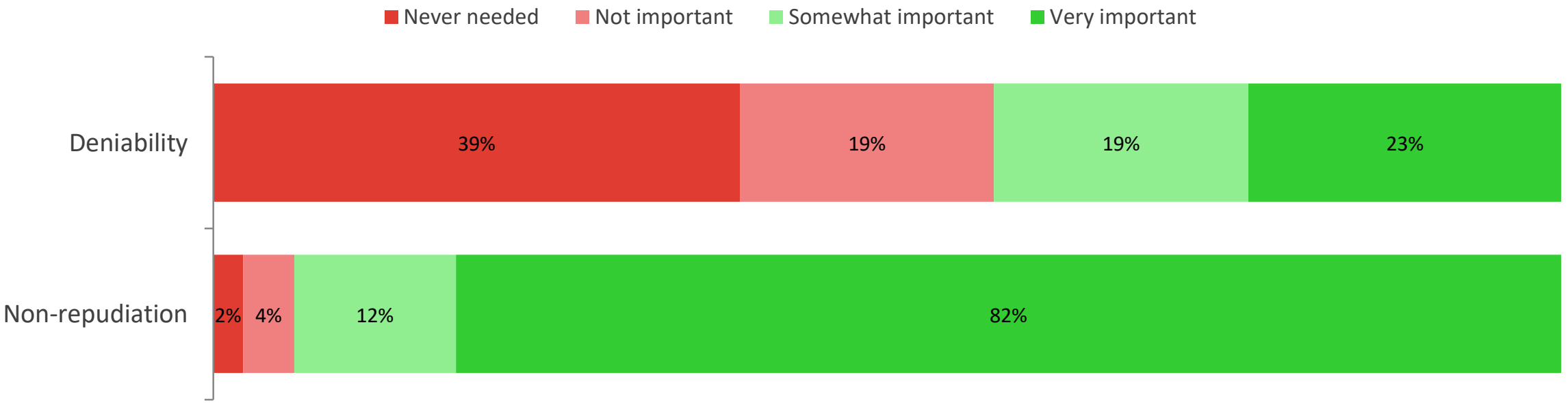


"… I feel like a lot of where this country is, it's partially because of the lack of any control and any fact-checking online. So I would go with non-repudiation to help combat this problem…"
— P12

29.6% want deniability in any combination; 77.4% want only one property

Adapted from the conference talk (slide 16) and Figure 9.

What do users actually need?



98%

could describe a time they needed non-repudiation

61%

could describe a time they needed deniability

42% vs 29.6%

value deniability vs prefer it — some users may not know what they need

Figure 12 and Section 5.2.3. “Not important” and “somewhat important” for non-repudiation are approximate (read off the chart).

Discussion



1. The survey shows most people prefer non-repudiation. Does majority preference decide the default for a security property? What about minorities with high-stakes needs?

2. The study used US participants only. How might results differ in a country where messaging is surveilled or used as evidence by an authoritarian state?

3. Is a hypothetical survey a valid way to measure “social acceptance”? What would a better design look like?

Part 5

Legal acceptance

What happens when WhatsApp chats reach US courts?

Method: 228 court opinions from Westlaw



Westlaw queries

"WhatsApp" near evidence, admissib!, authenticat!, hearsay … or near forge, deny, inadmissib!, limine

228 unique cases

Judicial opinions where WhatsApp chats might be accepted or rejected as evidence

Coding with a legal expert

Two researchers + a senior BYU law student, independently, then reconciled

Major

could make or break a case on its own

Minor

circumstantial; corroborates the story

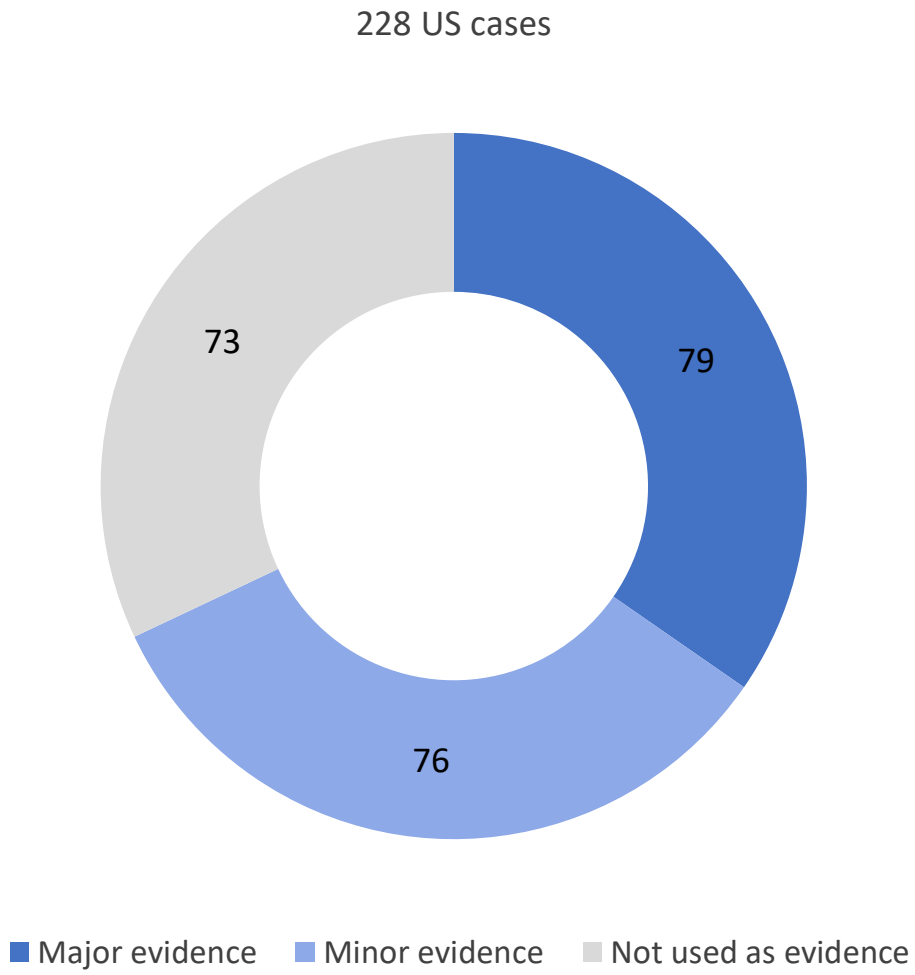
Rejected

excluded because of forgeability or deniability

N/A

WhatsApp mentioned for other reasons

Courts routinely accept WhatsApp chats



34.6% major evidence (79 cases)

33.6% minor evidence (76 cases)

0 rejected because a chat could be forged

No case presented an argument for cryptographic deniability.

Five themes from the court opinions



Forgery claims need evidence

In US v. Ojimba the defendant called WhatsApp messages unreliable; the court overruled the objection for lack of evidence and left reliability to the jury.



Deleted ≠ gone

In US v. Ozbirn, forensics on the sender's phone recovered messages matching the recipients' screenshots.



Prior history undermines denial

Past acts may show motive or intent; US v. Ramirez-Frechel admitted chats from after the charged date as evidence of gun dealing.



Encryption as suspicion

In US v. Ciuca, an affidavit cited WhatsApp's strong encryption as a reason criminals use it.

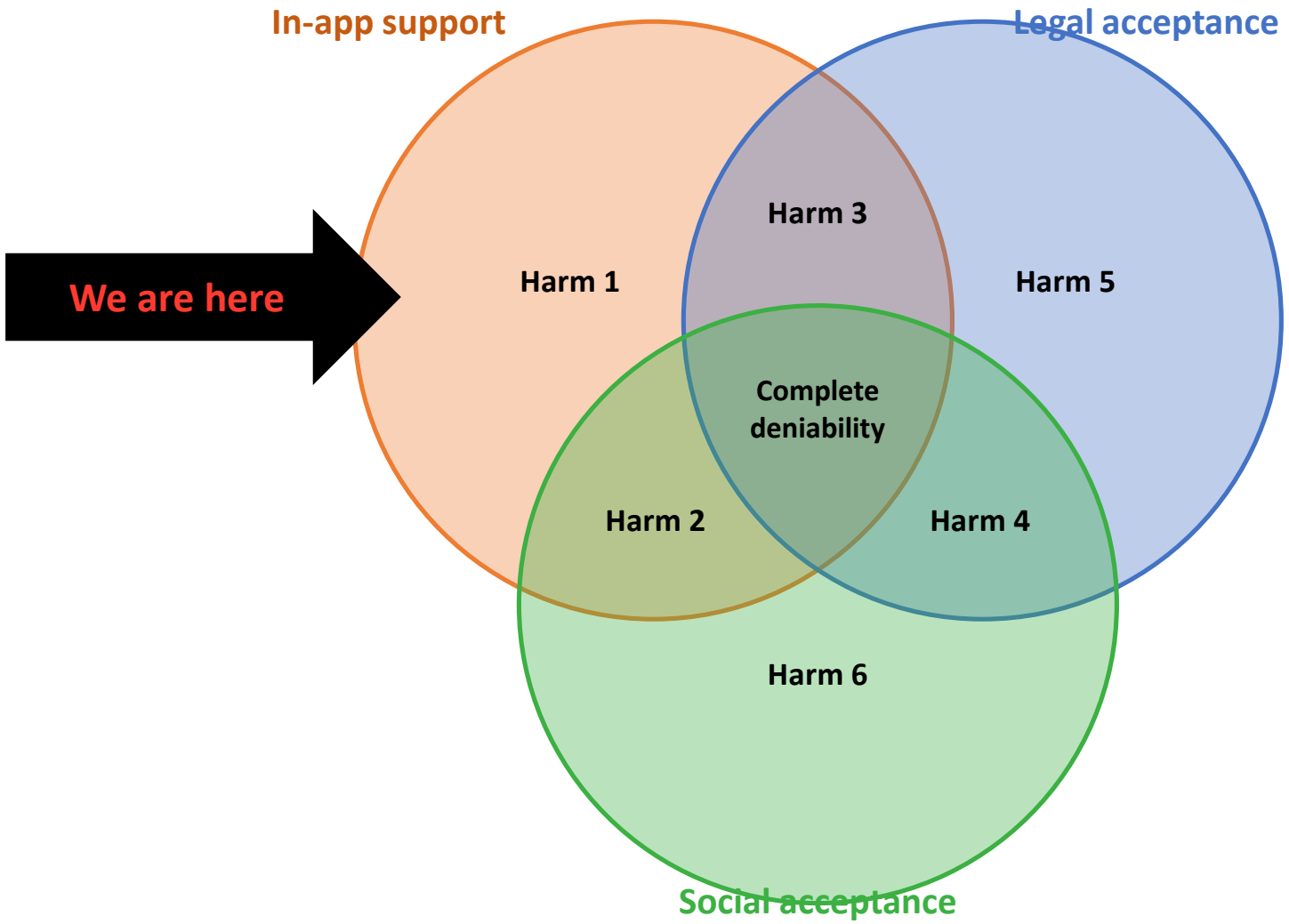


Screenshots can suffice

In US v. Avenatti, screenshots taken in investigators' presence plus an export were accepted given chain of custody.

No opinion relied on digital signatures to authenticate a message. Authenticity came from testimony, chain of custody and forensics.

Putting it together: where are we?



- In-app: ✓ WhatsApp and Signal are deniable
- Social: ✗ chats trusted far more than speech
- Legal: ✗ no court has weighed deniability
- **Result: Harm 1 — forged chats would be believed by friends and courts**

Part 6

Discussion and takeaways

What should designers, courts and researchers do next?

Why deniability is hard to achieve in practice



Your phone testifies against you

The message may still be on the sender's own device



Deleting isn't enough

Forensic analysts can recover deleted messages



Metadata outside your control

An ISP or provider may show who talked to whom and when



People don't believe you

Social trust in chats outweighs a claim of forgery



No guidance for users

Users lack reliable advice on what to do if they want to deny

Takeaways for different stakeholders



App developers

Revisit defaults: deniability-by-default may not suit non-experts. Explore offering both properties without overloading users.



Protocol designers

Write user-friendly definitions; OTR's wording produces both false security and distrust. Time-based schemes lack user demand.



Legal stakeholders

Courts accept chats as evidence; raise awareness that a deniable app lets a recipient forge messages.



Researchers

Study vulnerable groups who need deniability; how to raise awareness and social acceptance; non-US jurisdictions.

Limitations and related work

Limitations

- US participants and US courts only
- Prolific samples ≠ general population
- Abstract, hypothetical scenarios
- Possible priming toward non-repudiation
- Participants may have misread definitions
- Legal coding by a senior law student, not a practising lawyer

Closest related study

Reitinger et al., "Is Cryptographic Deniability Sufficient?", IEEE S&P 2023

- Mock-jury framing: a politician accused of bribery via a chat screenshot
- Same headline result: participants don't accept deniability
- This paper adds personal relationships, medium (oral / screenshot / in-app), preferences, and real court cases

Key takeaways

1 **Deniability is ineffective for vulnerable groups**
it only works if society and courts accept it — today they don't

2 **Users are open to social engineering**
forged chats are trusted, especially from untrustworthy people

3 **Deniability should not be the default for non-experts**
most users want and need non-repudiation

4 **Deniability has a bad reputation**
users associate it with misinformation and evading accountability

5 **The definition needs improvement**
OTR's wording misleads nearly everyone who reads it

Further reading and homework

Read

- Yadav, Gosain, Seamons — USENIX Security 2023 (today's paper)
- Borisov, Goldberg, Brewer — Off-the-record communication, WPES 2004
- Reitinger et al. — Is Cryptographic Deniability Sufficient?, IEEE S&P 2023
- Vatandas et al. — On the cryptographic deniability of the Signal protocol, ACNS 2020
- Specter, Park, Green — KeyForge, USENIX Security 2021

Homework (choose one)

- Rewrite OTR's deniability definition in under 40 words for a general audience; test it on two people and report what they understood
- Design a follow-up study for a non-US country: sampling, scenarios, and how you would search that country's court records
- Write a one-page position: should WhatsApp keep deniability on by default?

Any questions?

Cryptographic Deniability: A Multi-perspective Study of User Perceptions and Expectations · USENIX Security 2023